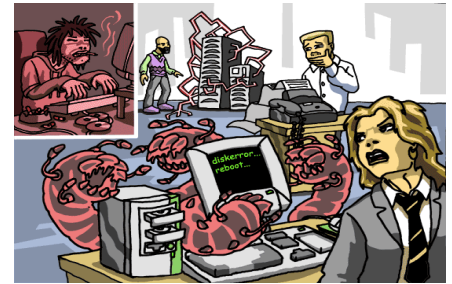


Einführung IT-Security

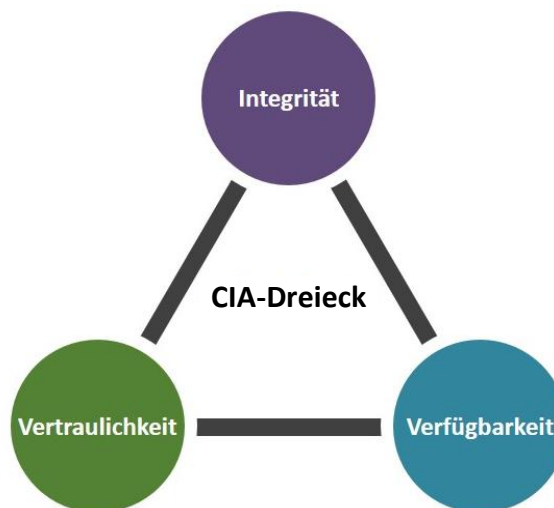
Aufgrund von Sicherheitslücken in der Informationstechnik treten unterschiedliche Schäden in Unternehmen aber auch bei Privatpersonen auf. Einen Eindruck vermitteln einige Aussagen aus der Studie "IT-Security":

- 1,2 Millionen Tage Ausfall hatten die Computersysteme deutscher Unternehmen in einem Jahr durch **Attacken** auf die IT-Infrastruktur.
- 42 Prozent der Angriffe sind nach Ansicht der Unternehmen auf Computerviren zurück zu führen. Als Urheber vermuten die Firmen zu 42 Prozent **Hacker** und zu 32 Prozent **eigene Mitarbeiter**.
- Als Auswirkungen von Angriffen nannten 35 Prozent der Unternehmen **Ausfälle** von EDV-Programmen oder E-Mail-Systemen, 24 Prozent Netzwerkausfälle und 13 Prozent **Diebstahl vertraulicher Informationen**.



Schutzziele der Informationssicherheit (Was wird angegriffen?)

Die Daten eines Geschäftsprozesses bzw. eines Systems müssen geschützt werden. Aber auf was genau gilt es dabei zu achten? Die IT-Sicherheit definiert drei grundlegende Schutzziele (auch als **Grundwerte** bekannt), die durch Angriffe auf IT-Systeme bedroht werden. Sie werden mit **C I A** abgekürzt.



- Unbefugte können nicht mitlesen →
- Die Nachricht ist vor Manipulation geschützt →
- Verhinderung von Systemausfällen →

In bestimmten Bereichen der IT-Sicherheit wird ein viertes Schutzziel, die **Authenticity** (= Authentizität) definiert. Diese dient auch der **Non-Repudiation**, was etwas hölzern als *Nicht-Abstreitbarkeit* übersetzt wird. Dieses Thema ist im CIA-Dreieck im Schutzziel **Integrität** enthalten.

Schutzziel: Vertraulichkeit (Confidentiality)

Die meisten Daten und Informationen von Personen, Unternehmen und Organisationen sind schützenswert und dürfen der Öffentlichkeit nicht zugänglich gemacht werden. Eine Veröffentlichung bedeutet im besten Falle Image-Schaden und im schlimmsten Fall den Untergang des Unternehmens.



Warum ist Vertraulichkeit wichtig?

- **Schutz vor Wirtschaftsspionage** (die am weitesten verbreitetet und lukrativste Tätigkeit von sogenannten Black Hats und staatlich unterstützten Hackern)
- **Gesetzliche Vorgaben zum Datenschutz müssen erfüllt werden** (Eine unbefugte Veröffentlichung von z.B. Kreditkartendaten von Kunden verursacht in der Regel einen enormen Image-Schaden und kann auch für jeden einzelnen Kunden sehr teuer werden. Auch die Veröffentlichung von Patientendaten ist hochkritisch.)

Die Vertraulichkeit ist also für viele Daten sehr wichtig. Auf der anderen Seite gibt es immer auch Personen, die auf die jeweiligen Daten zugreifen müssen. Es ist also zum einen notwendig, **autorisierte Zugriffe** zu ermöglichen, und zum anderen, dafür zu sorgen, dass **nicht-autorisierte Zugriffe** unterbunden werden. Dabei erhält ein Benutzer oder eine Benutzergruppe in der Regel eine **eindeutige Kennung (ID)** und eine Möglichkeit, sich zu **authentifizieren** (engl. *to authenticate*). Ist seine **Authentizität** festgestellt, erhält er Zugriff auf diejenigen Daten, für die er **autorisiert** ist.

Schutzmaßnahmen

Die Maßnahmen zur Sicherstellung der Vertraulichkeit können ganz unterschiedlich aussehen und auf unterschiedlichen Ebenen ansetzen. Typische Maßnahmen sind:

- **Verschlüsselung:** Die wohl wichtigste Maßnahme zur Sicherstellung der Vertraulichkeit im Rahmen der Netzwerk-Kommunikation. Sie stellt sicher, dass ein Angreifer den Inhalt einer Kommunikation nicht erkennen kann.
- **Firewalls:** Klassisches Instrument zur Steuerung von Netzwerk-Traffic und Verhinderung von unerwünschter Kommunikation.
- **Virenschutzsysteme:** Auch Antivirus-Systeme (kurz: AV) genannt. Dienen zum Verhindern von **Malware** (böartiger Software).
- **Intrusion-Detection / Intrusion-Prevention-Systeme:** Kurz: IDS/IPS, dienen der Erkennung von Angriffsmustern und – im Falle von IPS – auch der automatischen Abwehr des Angriffs.
- **Application Gateways:** Analysieren die Kommunikation auf Protokollebene bis in die Details und können fehlerhafte und unerwünschte Kommunikation erkennen und blockieren.
- **Zugangskontrollsysteme:** Sowohl physische als auch logische Systeme dienen dazu, den Zugriff auf zu schützende Daten auf die autorisierten Personen zu beschränken.

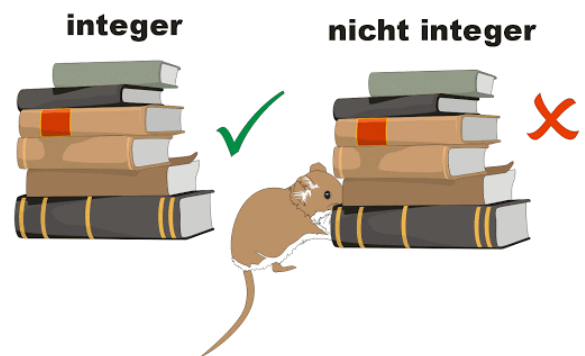
Schutzziel: Integrität (Integrity)

Hier wird die »Echtheit« der Daten betrachtet. Das Ziel ist es, Daten vor Manipulationen zu schützen.

Es war einmal ein Mitarbeiter, dem von seinem Unternehmen gekündigt wurde. Aus Rache führte er eine **Man-in-the-Middle-Attacke** aus, indem er ausgehende Angebotsmails des Unternehmens abfang und verändert an den Adressaten weiterleitete. Immer, wenn das Unternehmen ein Dienstleistungsangebot mit einem guten Preis an einen Interessenten schickte, veränderte er den Preis, so dass der Kunde statt 1500 Euro immer 15.000 Euro als Gesamtpreis las. Da die Kunden deshalb zur Konkurrenz wechselten, ging dem Unternehmen dadurch viel Geld verloren.

Warum ist Integrität wichtig?

- **Schutz vor Manipulation von gespeicherten Daten**
(Dateien auf einem Datenträger oder Server werden unbemerkt gegen eine geänderte Version ausgetauscht)
- **Schutz vor Manipulation während der Übertragung**
(Daten werden während der Übertragung zwischen Sender und Empfänger verändert)
- **Schutz vor Manipulation des Absenders** (Der Absender eines Datenpakets wird manipuliert. Hier geht es um die Authentizität, die mit Mitteln der Integrität sichergestellt werden kann)



Schutzmaßnahmen

- **Backups:** Sehr wichtig, wenn gelöschte oder geänderte Datei – egal ob absichtlich oder unabsichtlich – wiederhergestellt werden sollen. Kein Backup, kein Mitleid!
- **Zugangskontrollsysteme:** Auch beim Schutzziel Integrität sind Zugangskontrollsysteme hilfreich, um den Zugriff auf zu schützende Daten auf die autorisierten Personen zu beschränken.
- **Integritätsprüfung:** Die Original-Nachricht (oder -datei) wird als Eingangswert für eine Hash-Funktion verwendet. Daraus entsteht eine immer gleich lange Kombination aus Zeichen, das ist der **Hashwert (Fingerabdruck)**. Von diesem lässt sich nicht auf den Inhalt der Nachricht zurückschließen, aber er identifiziert diese ganz genau.

Der Sender verschickt seine Nachricht inklusive Hashwert an den Empfänger. Der Empfänger wendet dieselbe Hash-Funktion auf die Nachricht an und vergleicht den ermittelten Hashwert mit dem des Senders. Wurde an der Nachricht nur ein einziges Zeichen verändert, stimmen die Hashwerte nicht überein. Damit kann der Empfänger die Echtheit der empfangenen Daten überprüfen.

Vorsicht: Die Integritätsprüfung verhindert nicht die Manipulation der Daten! Es kann nur erkannt werden, ob Daten manipuliert wurden. Mehr kann die Integritätsprüfung nicht leisten.

- **Digitale Signatur:** Damit ein Angreifer Hashwerte nicht unerkannt ändern kann, muss der Hashwert geschützt werden. Dies geschieht z.B. mittels digitaler Signatur.
- **Digitale Zertifikate:** Digitale Signaturen kann sich jeder leicht selbst erstellen. Um Missbrauch vorzubeugen, erteilen Zertifizierungsstellen sogenannte digitale Zertifikate, um die Vertrauenswürdigkeit einer Person oder Organisationen zu beglaubigen.

Schutzziel: Verfügbarkeit (Availability)

Hier geht es um die technische Verfügbarkeit von Systemen, sowohl eines gewöhnlichen PC als auch von Servern im lokalen Netzwerk und Internet.

An Weihnachten 2014, wurden die Netzwerke der Spielekonsolen von Sony und Microsoft lahmgelegt. Die verschenkten Spiele, konnten erst einmal nur begrenzt zum Einsatz kommen, was den Herstellern viel Ärger einbrachte. Ursache dafür war ein sogenannter **DoS-Angriff (Denial-of-Service)**. Dies geschieht zum Beispiel durch eine Flut von Anfragen an das Zielsystem oder durch Ausnutzen einer bekannten Schwachstelle, die das System zum Absturz bringt. In diesem Fall reicht manchmal schon ein einziges, entsprechend manipuliertes Datenpaket. Um die Wirksamkeit solcher Angriffe zu erhöhen, werden **Distributed-Denial-of-Service-Angriffe (DDoS)** gefahren, bei denen der Angriff von Hunderten oder Tausenden Systemen aus dem Internet stattfindet.

Bei Beispielen mit DoS- und DDoS-Angriffen wird gerne vergessen, dass Systemausfälle in den meisten Fällen durch **Probleme mit der Stromversorgung** oder einfache **Hardwaredefekte** entstehen.

Warum ist Verfügbarkeit wichtig?

- **Wirtschaftlicher Schaden** (Wenn ein Online-Shop nicht erreichbar ist, kann kein Geld verdient werden)
- **Gefahr um Leib und Leben** (IT-Ausfälle können lebensgefährlich werden, z.B. in Eisenbahn-Stellwerken)

Schutzmaßnahmen

- **Backups:** Die wichtigste Schutzmaßnahme, um ein ausgefallenes System so schnell wie möglich wieder zum Laufen zu bekommen.
- **Redundanz:** Technische Systeme werden doppelt ausgelegt. Fällt ein System aus, springt das andere automatisch ein. Beispiele: Doppelte Netzteile, Hot-Spare-Festplatten bei RAID, ...
- **Unterbrechungsfreie Stromversorgung (USV):** Stromausfälle können überbrückt werden, bis die Systeme geordnet heruntergefahren sind. So können z.B. geöffnete Dateien noch gespeichert und Schäden an Dateisystemen und Datenbanken verhindert werden.
- **Notstromversorgung:** Bestimmte Systeme können bei Stromausfall nicht einfach abgeschaltet werden, z.B. in Krankenhäusern oder Rechenzentren. In diesen Fällen überbrückt eine USV die Zeit, bis die Notstromversorgung (oft ein Dieselaggregat) einsatzbereit ist.
- **High Availability (HA):** Auch hierbei werden redundante Systeme im Netzwerk bereitgestellt, die entweder parallel aktiv oder im Aktiv/Passiv-Modus arbeiten, also die Funktion sofort übernehmen können, wenn das Hauptsystem ausfällt.
- **Clustering:** Dabei werden mehrere gleichartige Systeme zu einem Verbund zusammengeschlossen. Fällt eines oder sogar mehrere dieser Verbundsysteme aus, können die anderen die Funktion trotzdem aufrechterhalten. Clustering unterscheidet sich von High Availability durch die Bereitstellung eines gemeinsamen Speichers.
- **Loadbalancing:** Dahinter versteckt sich das Konzept, die Anfragen von Client-Systemen automatisch nach bestimmten Kriterien auf verschiedene, gleichartige Systeme zu verteilen, um die Last aufzuteilen.

